BSI Standards Publication

BS EN 18239:2026

Digital Product Passport — Access rights management, information system security, and business confidentiality

数字产品护照 — 访问权限管理、信息系统安全与商业保密

ICS 13.020.20; 35.240.63

ISBN 978 0 539 37612 8

Published 2026-09-30

中英双语版 / Chinese-English Bilingual Edition

本文件为 BS EN 18239:2026 的中英双语对照翻译，仅供内部参考使用。
This is a bilingual translation for internal reference only.

Contents / 目录

European foreword / 欧洲前言 3

Introduction / 引言 4

1 Scope / 范围 6

2 Normative references / 规范性引用文件 6

3 Terms and definitions / 术语和定义 6

4 Business transactions and responsibilities / 业务交易与相关责任 7

5 Requirements for protection of business confidentiality / 商业保密保护要求 9

6 Requirements on system and service resilience / 系统与服务韧性要求 11

Annex A — Authentication assumptions / 认证假设（资料性） 14

Annex ZA — Relationship with Regulation (EU) 2024/1781 15

Bibliography / 参考文献 16

European Foreword / 欧洲前言

[English]

This document (EN 18239:2026) has been prepared by the Joint Technical Committee CEN-CENELEC/JTC 24 "Digital Product Passport — Framework and System", the secretariat of which is held by DIN.

This European Standard shall be given the status of a national standard, either by publication of an identical text or by endorsement, at the latest by March 2027, and conflicting national standards shall be withdrawn at the latest by March 2027.

Attention is drawn to the possibility that some of the elements of this document may be the subject of patent rights. CEN-CENELEC shall not be held responsible for identifying any or all such patent rights.

This document has been prepared under a standardization request addressed to CEN-CENELEC by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

For the relationship with EU Legislation, see informative Annex ZA, which is an integral part of this document.

Any feedback and questions on this document should be directed to the users' national standards body/national committee. A complete listing of these bodies can be found on the CEN and CENELEC websites.

According to the CEN-CENELEC Internal Regulations, the national standards organisations of the following countries are bound to implement this European Standard: Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and the United Kingdom.

> **[中文]**
>
> 本文件（EN 18239:2026）由 CEN-CENELEC 联合技术委员会 JTC 24"数字产品护照——框架与系统"编制，秘书处由 DIN 承担。
>
> 本欧洲标准最迟应于 2027 年 3 月前通过发布相同文本或认可的方式获得国家标准地位，相冲突的国家标准最迟应于 2027 年 3 月前撤销。
>
> 请注意，本文件的某些内容可能涉及专利权。CEN-CENELEC 不承担识别全部或部分此类专利权的责任。
>
> 本文件是在欧洲委员会向 CEN-CENELEC 提出的标准化请求下编制的。欧洲自由贸易联盟（EFTA）常设委员会随后批准了对其成员国的这些请求。
>
> 关于与欧盟法规的关系，参见资料性附录 ZA，该附录构成本文件的组成部分。
>
> 对本文件的任何反馈和问题应提交给用户所在国的国家标准机构/国家委员会。这些机构的完整名录可在 CEN 和 CENELEC 网站上找到。
>
> 根据 CEN-CENELEC 内部规章，以下国家的国家标准组织有义务实施本欧洲标准：奥地利、比利时、保加利亚、克罗地亚、塞浦路斯、捷克共和国、丹麦、爱沙尼亚、芬兰、法国、德国、希腊、匈牙利、冰岛、爱尔兰、意大利、拉脱维亚、立陶宛、卢森堡、马耳他、荷兰、挪威、波兰、葡萄牙、北马其顿共和国、罗马尼亚、塞尔维亚、斯洛伐克、斯洛文尼亚、西班牙、瑞典、瑞士、土耳其和英国。

Introduction / 引言

0.1 Background / 背景

A digital product passport (DPP) is a key enabling mechanism to make product information traceable and accessible across value chains — supporting economic operators, manufacturers, distributors, repairers, recyclers and consumers to make informed decisions and to support a circular economy. The implementation of DPPs will be carried out progressively. Sector-specific initiatives will determine the precise DPP content and requirements for individual product groups.

To support the implementation of DPPs, 8 standards have been developed:

— EN 18219:2026 – Digital product passport – Unique identifiers

— EN 18220:2026 – Digital product passport – Data carriers

— EN 18216:2026 – Digital product passport – Data exchange protocols

— EN 18222:2026 – Digital product passport – APIs for product passport lifecycle management and searchability

— EN 18223:2026 – Digital product passport – System interoperability

— EN 18221:2026 – Digital product passport – Data storage, archiving, and data persistence

— EN 18239:2026 – Digital product passport – Access rights management, information system security, and business confidentiality (this document)

— EN 18246:2026 – Digital product passport – Data authentication, reliability and integrity

> 数字产品护照（DPP）是实现产品信息在整个价值链中可追溯和可访问的关键赋能机制——支持经济运营者、制造商、分销商、维修商、回收商和消费者做出明智决策，并支持循环经济。DPP 的实施将逐步推进。特定行业倡议将确定各产品组的具体 DPP 内容和要求。
>
> 为支持 DPP 的实施，已制定 8 项标准：
>
> — EN 18219:2026 – 数字产品护照 – 唯一标识符
>
> — EN 18220:2026 – 数字产品护照 – 数据载体
>
> — EN 18216:2026 – 数字产品护照 – 数据交换协议
>
> — EN 18222:2026 – 数字产品护照 – 产品护照生命周期管理和可搜索性的 API
>
> — EN 18223:2026 – 数字产品护照 – 系统互操作性
>
> — EN 18221:2026 – 数字产品护照 – 数据存储、归档和数据持久性
>
> — EN 18239:2026 – 数字产品护照 – 访问权限管理、信息系统安全和商业保密（本文件）
>
> — EN 18246:2026 – 数字产品护照 – 数据认证、可靠性和完整性

0.2 Overview / 概述

This document aims at harmonizing the identity management that ensures that organisations, individuals, machines and services are provided with acknowledged identities. This document defines clear requirements related to access control measures to regulate the access to controlled DPP data.

This document defines rules and requirements related to:

— access right management;
— access control;
— clarification of DPP system roles and responsibilities to provide the means to define mechanisms on how to exchange access right information between economic operators, back-up system operators and registry of the regulated market controlling entity;

— measures to regulate the access to controlled DPP data;
— possibility for product group specific definition of access rights by relevant legal acts;
— information system security;
— business confidentiality and their representation in access rights management;
— differentiation of access rights of different user groups and authorities;
— guarantee of IT-security, cybersecurity, and data protection; and
— clarification of DPP system roles and responsibilities to provide the means to define mechanisms on how to transfer responsibilities, access-rights, and data from one economic operator to another.

EXAMPLE When a DPP will need to be updated to include information related to repair activities performed by a professional repairer.

本文件旨在协调身份管理，确保组织、个人、机器和服务获得公认的身份。本文件定义了与访问控制措施相关的明确要求，以规范对受控 DPP 数据的访问。

本文件定义了以下方面的规则和要求：

— 访问权限管理；
— 访问控制；
— 明确 DPP 系统角色和职责，为定义经济运营者、备份系统运营商和受监管市场控制实体登记处之间交换访问权限信息的机制提供手段；
— 规范受控 DPP 数据访问的措施；
— 由相关法律行为针对特定产品组定义访问权限的可能性；
— 信息系统安全；
— 商业保密及其在访问权限管理中的表示；
— 不同用户组和机构的访问权限区分；
— 保证 IT 安全、网络安全和数据保护；以及
— 明确 DPP 系统角色和职责，为定义将一个经济运营者的责任、访问权限和数据转移给另一个经济运营者的机制提供手段。

示例：当 DPP 需要更新以包含专业维修商执行的维修活动相关信息时。

1 Scope / 范围

This document specifies the requirements for digital product passport (DPP) access rights management, including IT security, data protection, and responsibility transfer between economic operators. It defines the framework for managing confidential information access, while acknowledging that public DPP data requires no access restrictions to be read.

> 本文件规定了数字产品护照（DPP）访问权限管理的要求，包括 IT 安全、数据保护和经济运营者之间的责任转移。它定义了管理机密信息访问的框架，同时确认公共 DPP 数据的读取不需要访问限制。

2 Normative references / 规范性引用文件

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

EN 18219:2026, Digital product passport — Unique identifiers

> 下列文件在文本中被引用，其部分或全部内容构成本文件的要求。对于注明日期的引用文件，仅引用的版本适用。对于未注明日期的引用文件，适用引用文件的最新版本（包括任何修订）。
>
> EN 18219:2026，数字产品护照 — 唯一标识符

3 Terms and definitions / 术语和定义

For the purposes of this document, the following terms and definitions apply:

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

— ISO Online browsing platform: available at https://www.iso.org/obp

— IEC Electropedia: available at https://www.electropedia.org/

> 就本文件而言，适用以下术语和定义：
>
> ISO 和 IEC 在以下地址维护用于标准化的术语数据库：
>
> — ISO 在线浏览平台：https://www.iso.org/obp
>
> — IEC Electropedia：https://www.electropedia.org/

3.1 controlled DPP data / 受控 DPP 数据

3.1 controlled DPP data
information on DPP whose access is controlled based on the user's access rights
[SOURCE: ISO 26800:2011, 2.10, modified]

> **受控 DPP 数据**
> 基于用户访问权限控制访问的 DPP 信息
> 【来源：ISO 26800:2011，2.10，修改】

3.2 system resilience / 系统韧性

3.2 system resilience
ability to recover from security compromises or attacks
[SOURCE: ISO/IEC 29180:2012]

> **系统韧性**
> 从安全泄露或攻击中恢复的能力
> 【来源：ISO/IEC 29180:2012】

3.3 system availability / 系统可用性

3.3 system availability
property of being accessible and usable on demand by an authorized actor
[SOURCE: EN ISO/IEC 27000:2020]

> **系统可用性**
> 经授权的主体可按需访问和使用的属性
> 【来源：EN ISO/IEC 27000:2020】

3.4 cyber resilience / 网络韧性

3.4 cyber resilience
ability to maintain business continuity despite adverse conditions, attacks, or compromises on critical data flow and related information systems

> **网络韧性**
> 尽管存在不利条件、攻击或关键数据流及相关信息系统的泄露，仍能维持业务连续性的能力

3.5 actor / 主体

3.5 actor
organization or individual that fulfils a role
[SOURCE: ISO 23234:2021, 3.4]

> **主体**
> 履行某一角色的组织或个人
> 【来源：ISO 23234:2021，3.4】

3.6 notified actor / 通知主体

3.6 notified actor

organization or individual entitled by an authorized accrediting body or authority, that fulfils a role in the DPP life cycle

> **通知主体**
> 由授权认证机构或主管部门授权、在 DPP 生命周期中履行某一角色的组织或个人

3.7 digital product passport (DPP) / 数字产品护照

3.7 digital product passport (DPP)

digital record of product characteristics throughout its life cycle

Note 1 to entry: Example characteristics include environment sustainability, environmental impact and recyclability.

> **数字产品护照（DPP）**
> 产品整个生命周期内产品特征的数字记录
> *注 1：示例特征包括环境可持续性、环境影响和可回收性。*

3.8 non-repudiation / 抗抵赖性

3.8 non-repudiation

ability to protect against denial by one of the entities involved in an action of having participated in all or part of the action

[SOURCE: ISO/IEC 29115:2013, 3.19]

> **抗抵赖性**
> 防止参与某动作的某一实体否认其参与全部或部分该动作的能力
> 【来源：ISO/IEC 29115:2013，3.19】

3.9 information/communication technology (ICT) / 信息通信技术

3.9 information/communication technology (ICT)
technology for gathering, storing, retrieving, processing, analysing and transmitting information
[SOURCE: ISO 9241-20:2021, definition 3.4]

> **信息通信技术（ICT）**
> 用于收集、存储、检索、处理、分析和传输信息的技术
> 【来源：ISO 9241-20:2021，定义 3.4】

3.10 identity proofing / 身份核验

3.10 identity proofing
process by which the registration authority captures and verifies sufficient information to identify an entity to a specified or understood level of assurance
[SOURCE: ISO/IEC 29115:2013, 3.15]

> **身份核验**
> 注册机构捕获并验证足够信息以将实体识别到指定或公认的保证级别的过程
> 【来源：ISO/IEC 29115:2013，3.15】

4 Business transactions and responsibilities related to the DPP / DPP 相关业务交易与责任

4.1 Business aspects of the DPP life cycle as basis of access management / DPP 生命周期的业务方面作为访问管理的基础

Access rights management is defined for the different life cycle phases and stages of a DPP. Such phases and stages are based on EN ISO 11354-1:2011.

In general, not all the phases and the stages mentioned in this document might be applicable to every product sector. Therefore, only the phases and stages relevant for a specific product group shall be considered. Moreover, in case a product group specific stage is not represented in the following list, it shall be considered during the access rights management implementation.

> 访问权限管理针对 DPP 的不同生命周期阶段和步骤进行定义。这些阶段和步骤基于 EN ISO 11354-1:2011。
>
> 一般而言，本文件中提到的所有阶段和步骤可能并不适用于每个产品行业。因此，仅应考虑与特定产品组相关的阶段和步骤。此外，如果以下列表中未包含特定产品组的阶段，应在访问权限管理实施过程中予以考虑。

4.2 Actors along the DPP life cycle / DPP 生命周期中的主体

This section identifies the main actors who are responsible for the handling of a DPP relevant product across the value chain and therefore need to access a DPP along its business stages. The identified actors are the following:

1. **Economic operators (in short EOs):** role encompassing the manufacturer, the authorized representative, the importer, the distributor, the dealer and the fulfilment service provider.
    a. **Manufacturers:** any natural or legal person that manufactures a product or that has a product designed or manufactured and markets that product under their name or trademark.

b. Authorized representatives: any natural or legal person established in the regulated market that has received a legally binding (e.g. written) mandate from the manufacturer to act on the manufacturer's behalf in relation to specified tasks with regard to the manufacturer's obligations.

c. Importers: any natural or legal person that places a product coming from outside the regulated market on the regulated market.

d. Distributors: any natural or legal person in the supply chain, other than the manufacturer or the importer, that makes a product available on the market.

e. Dealers: a distributor or any other natural or legal person that offers products for sale, hire or hire purchase, or that displays products to end users in the course of a commercial activity, including through distance selling; and includes any natural or legal person that puts a product into service in the course of a commercial activity.

f. Fulfilment service providers: any natural or legal person offering, in the course of commercial activity, services such as: warehousing, packaging, addressing and dispatching, without having ownership of the products involved.

4.2 Actors along the DPP life cycle (continued) / DPP 生命周期中的主体（续）

2. Other value chain actors

a. Consumers: individual member of the general public purchasing or using goods, property or services for private purposes [EN ISO 14025:2010, 3.16].

b. Professional repairers: a natural or legal person that provides professional repair or maintenance services for a product, irrespective of whether that person acts within the manufacturer's distribution system or independently.

c. Independent operators: natural or legal person that is independent of the manufacturer and is directly or indirectly involved in the refurbishment, repair, maintenance or repurposing of a product, and includes waste management operators, refurbishers, repairers, manufacturers or distributors of repair equipment, tools or spare parts, as well as publishers of technical information, operators offering inspection and testing services and operators offering training for installers, manufacturers and repairers of equipment.

d. Recycler: any natural or legal person who is responsible for the collection, processing and recovery of reusable materials and who applies a decontamination process.

e. Market surveillance authority: an authority designated by a Member State as responsible for carrying out market surveillance in the territory of that Member State.

3. Customs authorities: government service which is responsible for the administration of customs law and the collection of duties and taxes and which also has the responsibility for the application of other laws and regulations relating to the importation, exportation, movement or storage of goods.

4. Service provider: any natural or legal person providing an information service.

a. DPP service provider (main or back-up): a natural or legal person that is an independent third-party authorized by the EO which places the product on the market or puts it into service and that processes the DPP data for that product for the purpose of making such data available to EOs and other relevant actors with a right to access those data.

1. Main DPP service provider as "digital product passport service provider (EN 18221:2026, 3.3) that is hosting the main instance of the digital product passport (EN 18221:2026, 3.2), when the economic operator (EN 18221:2026, 3.1) chooses not to host the DPP itself".

2. Back-up DPP service provider as "digital product passport service provider that is hosting the back-up copy of the digital product passport" [EN 18221].

Other actors could be identified along the DPP life cycle from specific technical, organizational or legal requirements.

> **2. 其他价值链主体**
>
> **a. 消费者：**为私人目的购买或使用商品、财产或服务的普通公众个人 [EN ISO 14025:2010, 3.16]。
>
> **b. 专业维修商：**为产品提供专业维修或维护服务的自然人或法人，无论其是否在制造商的分销体系内运作或独立运作。
>
> **c. 独立运营者：**独立于制造商的自然人或法人，直接或间接参与产品的翻新、维修、维护或再利用，包括废物管理运营者、翻新商、维修商、维修设备/工具/备件的制造商或分销商，以及技术信息的发布者、提供检测和测试服务的运营者，和为设备安装商、制造商和维修商提供培训的运营者。
>
> **d. 回收商：**负责收集、加工和回收可再利用材料并应用去污过程的自然人或法人。
>
> **e. 市场监管机构：**由成员国指定的负责在该成员国领土内执行市场监管的机构。
>
> **3. 海关当局：**负责海关法管理、税费征收的政府服务机构，同时负责适用与货物进出口、移动或储存相关的其他法律法规。
>
> **4. 服务提供商：**提供信息服务的任何自然人或法人。

a. DPP 服务提供商（主要或备份）：由将产品投放市场或投入使用的 EO 授权的独立第三方自然人或法人，为该产品的 DPP 数据进行处理，以使这些数据可供 EO 和其他有权访问这些数据的相关主体使用。

1. 主要 DPP 服务提供商为"数字产品护照服务提供商（EN 18221:2026, 3.3），在经济运营者（EN 18221:2026, 3.1）选择不自托管 DPP 时托管数字产品护照（EN 18221:2026, 3.2）的主实例"。

2. 备份 DPP 服务提供商为"托管数字产品护照备份副本的数字产品护照服务提供商" [EN 18221]。

可根据特定技术、组织或法律要求，在 DPP 生命周期中识别其他主体。

5 Requirements for the protection of business confidentiality and the management of access rights / 商业保密保护与访问权限管理要求

5.1 General / 概述

Based on the product life cycle and the different business roles along this life cycle (4.2) the following requirements for DPP access rights management, information system security and business confidentiality hold.

> 基于产品生命周期及该生命周期中的不同业务角色（4.2），以下 DPP 访问权限管理、信息系统安全和商业保密要求适用。

5.2 Requirements for the protection of business confidentiality / 商业保密保护要求

1. Actors in a DPP system (see 4.2) shall have globally unique operator identifiers, as defined in EN 18219:2026.

2. Access to public data shall be possible without authentication.

NOTE 1 This requirement avoids discrimination based on, inter alia, geographical location.

3. Access and management of controlled DPP data shall not be prohibited based solely on an actor's location or jurisdiction.

4. Actors shall be able to obtain and provide (when requested) all the information needed for identification, authorization and accounting purposes, including the unique operator identifier.

NOTE 2 This requirement avoids discrimination based on, inter alia, geographical location.

5. Authentication of actors accessing or managing controlled DPP data shall allow for accountability. Management (including creation, modification and access) of controlled DPP data shall be implemented using mechanisms for non-repudiation.

6. The EO may assign certain rights and roles to any notified actor (see 4.2) that requires access to its controlled DPP data based on their globally unique operator identifier. Such access rights shall be product group specific and conform to the relevant legal act.

7. Roles granting access to regulated DPP data are defined per product group by relevant legal act. The EOs may grant additional access privileges.

8. Globally unique operator identifier shall be provided as part of the authentication process. For example, the globally unique operator identifier may be part of a trustworthy role credential, allowing for access to controlled DPP data without the need of individual EO's explicit approval.

9. For actors fulfilling additional roles not regulated but defined by the EO, the EO can decide which authentication mechanism to apply.

10. Access rights terms shall be defined at data element level. Controlled vocabularies, for example the EU Vocabularies section of the Publications Office of the European Union, may be considered for such terms.

11. Access to DPP services shall be limited in such a way as to prevent attacks or unauthorized mass data scraping.

12. To counteract DPP counterfeit, where authentication of the DPP issuer is required, the issuing EO shall be securely identified.

13. When authentication is required to access any service related to DPP management (e.g. issuing, amendment and access to controlled DPP data), such authentication shall be performed according to the relevant legal act.

NOTE 3 The best practice/guidelines are outlined in Annex A.

5.2 Requirements (continued) / 要求（续）

14. Measures to detect, counter, or mitigate anomalies that affect service availability may be implemented.

15. An EO may introduce "access rate limiting" in case of reasonable, identified risks or legal requirement, if legal information requirements are not affected.

16. All access and changes to roles, rights, or controlled DPP data shall be logged and auditable. The log shall be protected from tampering, forging, deletion of data and shall provide evidence of integrity over time.

17. Any access rights management system managing access to controlled DPP data shall have clear and documented processes for granting, revoking or modifying access rights when roles change or actors are no longer authorized.

18. There shall be the possibility to delegate access roles. The actor receiving the delegation shall fulfil the legal obligation the role requires.

19. There shall be a mechanism to handle emergency access rights change (e.g. revocation) in case of breach or non-compliance. Additionally, the life cycle management of access rights to controlled DPP data may include issuing, termination, suspension and renewal.

20. Authorization to access and manage controlled DPP data shall be based upon the role of the entity requesting authorization. If such entity has been delegated by another entity to manage this kind of information, the authorization shall be given also on the delegating entity's role in relation to the data being accessed by the delegated entity, and the robustness and trustworthiness of the delegation itself.

21. Access management security should follow the guidelines in EN ISO/IEC 27000:2020, in particular Clause A.5 and Clause A.9, and EN ISO/IEC 27001:2023.

22. Access to all controlled DPP data shall be authenticated and authorized before being granted. When authentication is required to access any service related to DPP management (e.g. issuing, amendment and access to controlled data), such authentication shall be performed according to the relevant legal act. Least privilege principles shall be implemented.

NOTE 4 The best practice/guidelines are outlined in Annex A.

23. Access rights shall be enforceable at controlled data element granularity according to the requesting actor's role (including product group specific roles).

24. Measures shall be put in place to avoid profiling of users. User profiling shall not be allowed unless authentication is strictly required to access a specific service.

14. 可实施检测、对抗或缓解影响服务可用性的异常的措施。

15. 在存在合理、已识别的风险或法律要求的情况下，如果法律信息要求不受影响，EO 可引入"访问速率限制"。

16. 对角色、权限或受控 DPP 数据的所有访问和更改均应记录并可审计。日志应受到保护，防止篡改、伪造、数据删除，并应随时间提供完整性证据。

17. 任何管理受控 DPP 数据访问的访问权限管理系统，应在角色变更或主体不再被授权时，具有明确且有文件记录的权利授予、撤销或修改流程。

18. 应具备委托访问角色的可能性。接受委托的主体应履行该角色所要求的法律义务。

19. 应建立机制以处理在发生泄露或不合规时的紧急访问权限变更（例如撤销）。此外，受控 DPP 数据访问权限的生命周期管理可包括签发、终止、暂停和续期。

20. 访问和管理受控 DPP 数据的授权应基于请求授权的实体的角色。如果该实体已被另一实体委托管理此类信息，则授权还应基于委托实体相对于被委托实体所访问数据的角色，以及委托本身的稳健性和可信度。

21. 访问管理安全应遵循 EN ISO/IEC 27000:2020 中的指南，特别是条款 A.5 和条款 A.9，以及 EN ISO/IEC 27001:2023。

22. 在授予所有受控 DPP 数据访问权限之前，应先进行认证和授权。当访问与 DPP 管理相关的任何服务（例如签发、修改和访问受控数据）需要认证时，此类认证应根据相关法律行为进行。应实施最小权限原则。

注 4：最佳实践/指南在附录 A 中概述。

23. 访问权限应根据请求主体的角色（包括特定产品组的角色）在受控数据元素粒度级别上可执行。

24. 应采取措施避免用户画像。除非访问特定服务严格需要认证，否则不允许用户画像。

6 Requirements on system and service resilience / 系统与服务韧性要求

6.1 General requirements / 通用要求

There shall be no authentication to read access of public DPP data. The authentication functionality should be simple, reliable and secured. To access and amend controlled data, the authentication is required.

The authentication process, where required, shall apply to both actors and system components.

> 对公共 DPP 数据的读取访问不应要求认证。认证功能应简单、可靠且安全。访问和修改受控数据需要认证。
>
> 在需要认证的情况下，认证过程应同时适用于主体和系统组件。

6.2 Access management / 访问管理

From the functional requirements specified in Clause 5 the following requirements for access management arise.

EOs control the access to DPP data of products they are liable for. Access schemes to DPP data can be separated into:

1. Unauthenticated access to public DPP data: read-only access to publicly available DPP information by any actor.

2. Authenticated access to controlled DPP data: Role based access to controlled DPP data; e.g. access by authorities, access by parties with roles defined by regulation. Different roles will permit different operations on specific sets of data.

> 由第 5 条规定的功能要求产生以下访问管理要求。
>
> EO 控制其负责的产品的 DPP 数据访问。DPP 数据的访问方案可分为：
>
> **1.** 对公共 DPP 数据的未认证访问：任何主体对公开可用 DPP 信息的只读访问。
>
> **2.** 对受控 DPP 数据的认证访问：基于角色的受控 DPP 数据访问；例如，主管部门的访问、具有法规定义角色的各方的访问。不同角色将允许对特定数据集执行不同的操作。

6.3 Access revoking policy / 访问撤销策略

A policy for "access revocation" shall be put in place for the DPP system and services.

> 应为 DPP 系统和服务制定"访问撤销"策略。

6.4 Digital operational resilience / 数字运营韧性

6.4.1 General / 概述

Digital operational resilience aims at the resilience of the overall supply chain of ICT services [6, 8], ICT systems or ICT products throughout their life cycle against disruptive events.

> 数字运营韧性旨在实现 ICT 服务 [6, 8]、ICT 系统或 ICT 产品在整个生命周期中针对破坏性事件的整体供应链韧性。

6.4.2 Business continuity / 业务连续性

Business Continuity Management (BCM) manages risks from attacks against the availability of systems and should be implemented according to the following international standards:

— EN ISO 22301:2019 [1]; and

— ISO/IEC 27031:2025 [5].

NOTE Attention is drawn to existing local regulations that can apply.

> 业务连续性管理（BCM）管理针对系统可用性的攻击风险，应根据以下国际标准实施：
>
> — EN ISO 22301:2019 [1]；以及
>
> — ISO/IEC 27031:2025 [5]。
>
> *注：请注意可能适用的现有地方法规。*

6.4.3 Continuous improvement / 持续改进

As security is a moving target, continuous improvement (CI) of all security measures and policies is important for the support of digital operational resilience and should be put in place.

> 由于安全是一个不断变化的目标，所有安全措施和策略的持续改进（CI）对支持数字运营韧性至关重要，应予以建立。

6.5 Security management / 安全管理

6.5.1 Service availability / 服务可用性

The availability and timely accessibility of digital product data are essential as defined by/in implementing acts.

> 数字产品数据的可用性和及时可访问性至关重要，如实施法案中所定义。

6.5.2 Security by design / 安全设计

Services managing DPP data should be designed and managed following security-by-design and defence in depth methodologies. A security by design approach should be followed in design, implementation and maintenance of all the DPP related systems and services. Measures on how to uphold and preserve reliable, resilient and secure information systems during the whole life cycle of critical DPP data shall be identified and implemented. Thereby the following aspects shall be assessed and considered:

— overall quality and resilience of products and services;
— cybersecurity risk-management measures embedded in them; and
— cybersecurity practices of their suppliers and service providers, including their secure development procedures.

Cybersecurity risk-management measures should be included into contractual arrangements with direct suppliers and service providers.

> 管理 DPP 数据的服务应遵循安全设计和纵深防御方法论进行设计和管理。在所有 DPP 相关系统和服务的设计、实施和维护中应遵循安全设计方法。应识别并实施在关键 DPP 数据整个生命周期内维护和保持可靠、有韧性和安全的信息系统的措施。应评估和考虑以下方面：
>
> — 产品和服务的整体质量和韧性；
> — 嵌入其中的网络安全风险管理措施；以及
> — 其供应商和服务提供商的网络安全实践，包括其安全开发程序。

网络安全风险管理措施应纳入与直接供应商和服务提供商的合同安排中。

6.5.3 Incident detection and response / 事件检测与响应

Cybersecurity risk-management measures should consider critical data flows and related information systems and include measures related to the prevention, detection, identification, containment, analysis and response to incidents.

> 网络安全风险管理措施应考虑关键数据流和相关信息系统，并包括与事件预防、检测、识别、遏制、分析和响应相关的措施。

6.5.4 Recovery capability / 恢复能力

Critical data flows and related information systems should be equipped with redundant systems and back-up resources to ensure continuity. There should be resilience mechanisms implemented to mitigate Denial-of-Service (DoS) attacks and allow for the recovery to a stable state in the event of such an attack.

> 关键数据流和相关信息系统应配备冗余系统和备份资源以确保连续性。应实施韧性机制以缓解拒绝服务（DoS）攻击，并在此类攻击发生时恢复到稳定状态。

6.5.5 Continuous improvement / 持续改进

CI processes for Information Security Management System (ISMS) should be put in place for DPP systems and services. Such processes may be implemented in accordance with EN ISO/IEC 27001:2023.

The process for establishing and maintaining ISMS should be based on a Plan-Do-Check-Act (PDCA) cycle to ensure systematic enhancement of information security.

Planning (Plan): The organization should establish objectives and scope for the ISMS. A comprehensive risk assessment should be conducted to identify potential threats and vulnerabilities. Appropriate security controls should be selected and documented based on the risk assessment.

Implementation (Do): The organization should implement the security controls defined in the planning phase. All personnel should be trained and made aware of their roles and responsibilities regarding information security. Necessary security measures should be deployed, and policies shall be enforced.

Monitoring and review (Check): The effectiveness of the implemented controls should be continuously monitored and reviewed. Key performance indicators (KPIs) should be measured and analysed to assess the health of the ISMS.

Improvement (Act): Corrective and preventive actions should be taken based on the results of monitoring and review. Processes should be proactively enhanced to improve the ISMS. Continuous improvement should be ensured by addressing identified issues and implementing necessary changes.

> 应为 DPP 系统和服务建立信息安全管理体系（ISMS）的持续改进流程。此类流程可根据 EN ISO/IEC 27001:2023 实施。
>
> 建立和维护 ISMS 的流程应基于计划-执行-检查-改进（PDCA）循环，以确保信息安全的系统性提升。
>
> **策划（Plan）：** 组织应确立 ISMS 的目标和范围。应进行全面的风险评估以识别潜在威胁和脆弱性。应根据风险评估选择并记录适当的安全控制措施。
>
> **执行（Do）：** 组织应实施在策划阶段定义的安全控制措施。所有人员应接受培训并了解其在信息安全方面的角色和职责。应部署必要的安全措施，并强制执行政策。
>
> **检查（Check）：** 应持续监控和审查已实施控制措施的有效性。应测量和分析关键绩效指标（KPI）以评估 ISMS 的健康状况。

> **改进（Act）：** 应根据监控和审查的结果采取纠正和预防措施。应主动改进流程以提升 ISMS。应通过解决已识别的问题并实施必要的变更来确保持续改进。

Annex A (informative)
Authentication assumptions / 认证假设（资料性）

Authentication to manage controlled DPP data is based on the following assumptions, considering the risk associated with erroneous authentication:

1. Relevant identity data for identity proofing and verification has been collected.

2. There is a strong confidence in the claimed or asserted identity of the entity being authenticated.

3. Multifactor authentication is employed with at least two different authentication factors.

4. The electronic identification means is designed in such a way that it could be reasonably assumed that, when it is used, it is under the sole control of the entity (natural or legal person) to whom it belongs.

5. All relevant cryptographic information exchanged in the authentication process is protected while in transit and at rest.

6. The claimed identity of the entity (natural or legal person) is demonstrated on the basis of evidence recognized by an authoritative source and it is checked against such source.

7. Steps have been taken to minimize the risk that the evidence of identity was lost, stolen, suspended, revoked or based on expired documents.

8. The binding between the authentication means and the identity is based on recognized procedures and it is registered in an authoritative source and has been verified on the basis of information from that source.

9. The electronic identification means is delivered in a way that provides the reasonable assumption that it is delivered only into the possession of the person to whom it belongs.

10. Suspension and revocation of the electronic identification means could be done in a timely manner.

11. Personal identification data are released only after a reliable verification of the electronic identification means has been performed by a dynamic authentication.

> 管理受控 DPP 数据的认证基于以下假设，同时考虑错误认证相关的风险：
>
> **1.** 已收集用于身份核验和验证的相关身份数据。
>
> **2.** 对被认证实体声称或断言的身份具有高度信心。
>
> **3.** 采用多因素认证，至少使用两种不同的认证因素。
>
> **4.** 电子身份识别手段的设计使得可以合理假设，在使用时，它仅处于其所属实体（自然人或法人）的单独控制之下。
>
> **5.** 认证过程中交换的所有相关加密信息在传输和静态存储时均受到保护。
>
> **6.** 实体（自然人或法人）的声称身份基于权威来源认可的证据予以证明，并与该来源进行核对。
>
> **7.** 已采取措施最大限度地降低身份证明丢失、被盗、暂停、撤销或基于过期文件的风险。
>
> **8.** 认证手段与身份之间的绑定基于公认的程序，已注册在权威来源中，并已根据该来源的信息进行验证。
>
> **9.** 电子身份识别手段的发放方式使得可以合理假设其仅交付给所属之人。
>
> **10.** 电子身份识别手段的暂停和撤销可及时进行。
>
> **11.** 个人身份数据仅在通过动态认证对电子身份识别手段进行可靠验证后才予释放。

Annex ZA (informative)
Relationship with Regulation (EU) 2024/1781 / 与欧盟法规的关系（资料性）

This European Standard has been prepared under a Commission's standardization request M/604/C(2024)5423 to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/1781 of the European Parliament and of the Council of 13 June 2024 establishing a framework for the setting of ecodesign requirements for sustainable products (OJ L, 2024/1781).

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in Table ZA.1 confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding requirements of that Regulation, and associated EFTA regulations.

Table ZA.1 — Correspondence / 对应关系

Requirements of Regulation (EU) 2024/1781	Clause(s) of this EN	Remarks/Notes
Article 11(a)	4.2	Limited to organisational interoperability as regards end-to-end communication and data transfer

WARNING 1 — Presumption of conformity stays valid only as long as a reference to this European Standard is maintained in the list published in the Official Journal of the European Union.

WARNING 2 — Other Union legislation may be applicable to the product(s) falling within the scope of this standard.

本欧洲标准是在委员会标准化请求 M/604/C(2024)5423 下编制的，旨在提供一种自愿性手段，以符合欧洲议会和理事会 2024 年 6 月 13 日关于建立可持续产品生态设计要求的框架的第 (EU) 2024/1781 号法规的要求（OJ L, 2024/1781）。

一旦本标准在该法规下的欧盟官方公报中被引用，遵守表 ZA.1 中给出的本标准的规范性条款，在本标准范围内，即推定为符合该法规及相关的 EFTA 法规的相应要求。

表 ZA.1 — 对应关系

(EU) 2024/1781 法规的要求	本 EN 的条款	备注
第 11(a) 条	4.2	限于端到端通信和数据传输方面的组织互操作性

警告 1 — 符合性推定仅在欧盟官方公报公布的清单中保留对本欧洲标准的引用期间有效。

警告 2 — 其他联盟立法可能适用于属于本标准范围内的产品。

Bibliography / 参考文献

[1] EN ISO 22301:2019, Security and resilience — Business continuity management systems — Requirements (ISO 22301:2019)

[2] EN ISO/IEC 27000:2020, Information technology — Security techniques — Information security management systems — Overview and vocabulary (ISO/IEC 27000:2018)

[3] ISO/IEC 29180:2012, Information technology — Security framework for ubiquitous sensor networks

[4] EN ISO/IEC 27001:2023, Information security, cybersecurity and privacy protection — Information security management systems — Requirements — Amendment 1: Climate action changes (ISO/IEC 27001:2022)

[5] ISO/IEC 27031:2025, Cybersecurity — Information and communication technology readiness for business continuity

[6] ISO/IEC 27036-3:2023, Cybersecurity — Supplier relationships — Part 3: Guidelines for hardware, software, and services supply chain security

[7] ISO/IEC 27036-4:2016, Information technology — Security techniques — Information security for supplier relationships — Part 4: Guidelines for security of cloud services

[8] ISO 28003:2007, Security management systems for the supply chain — Requirements for bodies providing audit and certification of supply chain security management systems

[9] ISO 23234:2021, Buildings and civil engineering works — Security — Planning of security measures in the built environment

[10] ISO/IEC 29115:2013, Information technology — Security techniques — Entity authentication assurance framework

[11] EN ISO 11354-1:2011, Advanced automation technologies — Requirements for establishing manufacturing enterprise process interoperability — Part 1: Framework for enterprise interoperability (ISO 11354-1:2011)

[12] ISO 9241-20:2021, Ergonomics of human-system interaction — Part 20: An ergonomic approach to accessibility

[13] ISO 26800:2011, Ergonomics — General approach, principles and concepts

> [1] EN ISO 22301:2019，安全与韧性 — 业务连续性管理体系 — 要求（ISO 22301:2019）
>
> [2] EN ISO/IEC 27000:2020，信息技术 — 安全技术 — 信息安全管理体系 — 概述和词汇（ISO/IEC 27000:2018）
>
> [3] ISO/IEC 29180:2012，信息技术 — 泛在传感器网络安全框架
>
> [4] EN ISO/IEC 27001:2023，信息安全、网络安全和隐私保护 — 信息安全管理体系 — 要求 — 修订 1：气候行动变更（ISO/IEC 27001:2022）
>
> [5] ISO/IEC 27031:2025，网络安全 — 业务连续性的信息和通信技术准备
>
> [6] ISO/IEC 27036-3:2023，网络安全 — 供应商关系 — 第 3 部分：硬件、软件和服务的供应链安全指南
>
> [7] ISO/IEC 27036-4:2016，信息技术 — 安全技术 — 供应商关系信息安全 — 第 4 部分：云服务安全指南
>
> [8] ISO 28003:2007，供应链安全管理体系 — 提供供应链安全管理体系审核和认证的机构的要求
>
> [9] ISO 23234:2021，建筑和土木工程 — 安全 — 建筑环境中安全措施的规划
>
> [10] ISO/IEC 29115:2013，信息技术 — 安全技术 — 实体认证保证框架
>
> [11] EN ISO 11354-1:2011，先进自动化技术 — 建立制造企业过程互操作性的要求 — 第 1 部分：企业互操作性框架（ISO 11354-1:2011）

[12] ISO 9241-20:2021，人-系统交互工效学 — 第 20 部分：可访问性的工效学方法

[13] ISO 26800:2011，工效学 — 通用方法、原则和概念